


**Trường Đại học Công nghệ – Đại học Quốc gia Hà Nội**

**Khoa Công nghệ Thông tin**

# Tổng Quan Kiến Trúc, Lịch Sử Tiến Hóa và Cơ Chế Cốt Lõi của Giao Thức SSL/TLS

## Học phần: Mật mã và An toàn Thông tin

**Sinh viên thực hiện:**

Lê Minh Sơn
Mai Tiến Dũng
Nguyễn Nho Dương

**Giảng viên:**

TS. Lê Thị Hợi

**Ngày:**

09 tháng 11 năm 2026

# Cấu Trúc Nội Dung Thuyết Trình

## 5 Phần Nội Dung Chính

1. **Định Vị Kiến Trúc & 4 Dịch Vụ Bảo Mật**
   Vị trí TCP/IP, đối sánh IPsec; Bí mật, Toàn vẹn, Xác thực, Chống phát lại.
2. **Lịch Sử Tiến Hóa & Chu Kỳ Đào Thải**
   Từ Netscape SSL 1.0–3.0 đến IETF TLS 1.0–1.3; quy chuẩn BCP 195.
3. **Kiến Trúc Phân Tầng & Giao Thức Lõi**
   Session vs. Connection; 5 bước Record; CCS, Alert & 4 pha Handshake.
4. **Cơ Chế Mật Mã Học, Dẫn Xuất Khóa & PKI**
   Giải phẫu Cipher Suite, chuẩn PFS, hàm PRF và chứng thư X.509 v3.
5. **Tổng Kết & 3 Bài Học Kiến Trúc Mật Mã**
   Cấm hạ cấp tuyệt đối, hợp nhất AEAD và bắt buộc khóa phù du PFS.

## Mục Tiêu Trình Bày

- Giải thích vì sao SSL/TLS đặt ở ranh giới giữa tầng Giao vận và Ứng dụng.
- Hệ thống hóa lý do khai tử các phiên bản từ SSL 1.0 đến TLS 1.1.
- Trình bày rõ luồng đóng gói bản ghi, 4 pha bắt tay và cách dẫn xuất khóa phiên.
- Đúc kết các nguyên lý thiết kế bảo mật hiện đại trên TLS 1.2 và TLS 1.3.

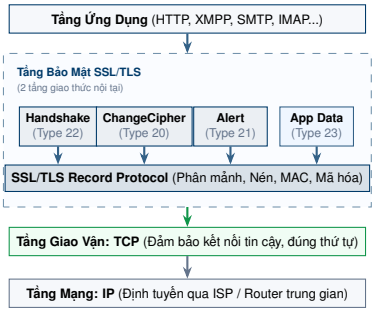
# Khái Niệm & Định Vị SSL/TLS trong Mô Hình TCP/IP



## Khái Niệm, Định Nghĩa & Vị Trí Kiến Trúc

- **SSL (*Secure Sockets Layer*)**: Netscape phát triển (1994), bảo mật Web.
- **TLS (*Transport Layer Security*)**: Chuẩn IETF kế thừa, thay thế SSL.
- **Mục tiêu**: Kênh end-to-end, bảo đảm bí mật, toàn vẹn và xác thực.
- **Vị trí TCP/IP**: Nằm giữa TCP và Ứng dụng; chạy ở *user-space*.
- **Đánh đổi vs. IPsec**: IPsec bảo vệ toàn mạng; SSL/TLS cô lập ở 2 đầu mút.

## Vị Trí Kiến Trúc Hai Tầng của SSL/TLS



# Bốn Dịch Vụ Bảo Mật Cốt Lõi của SSL/TLS

### 1. Tính Bí Mật (Confidentiality)

- **Chống nghe lén**: Mã hóa dữ liệu bằng khóa đối xứng phiên tạo lập trong bắt tay.
- **Thuật toán**: `AES`, `ChaCha20`; chèn đệm (*padding*) che độ dài lưu lượng.

### 2. Tính Toàn Vẹn (Message Integrity)

- **Chống sửa đổi**: Phát hiện nếu gói tin bị can thiệp hoặc cắt bớt trên đường truyền.
- **Cơ chế**: Dùng mã xác thực `HMAC` (`SHA-256`) hoặc tích hợp nguyên tử trong bộ mã AEAD.

### 3. Xác Thực Định Danh (Authentication)

- **Chống mạo danh**: Server bắt buộc xác thực; Client xác thực tùy chọn (`mTLS`).
- **Cơ chế**: Khóa công khai (`RSA`, `ECDSA`) kết hợp chứng thư X.509 hoặc khóa chia sẻ `PSK`.

### 4. Chống Phát Lại (Replay Protection)

- **Chống lặp gói**: Ngăn chặn kẻ tấn công thu giữ gói tin hợp lệ rồi phát lại.
- **Cơ chế**: Nonces ngẫu nhiên khi bắt tay và bộ đếm `sequence_number` 64-bit ngầm định.

# Khởi Nguyên tại Netscape: Từ SSL 1.0 đến SSL 3.0

**Bối cảnh khởi nguồn (1994):** Netscape phát triển SSL phục vụ thương mại điện tử sơ khai (Taher Elgamal). Bản SSL 1.0 chỉ dùng nội bộ, không công bố do tồn tại khiếm khuyết an toàn cơ bản.

## SSL 2.0 (02/1995) – 5 Khiếm Khuyết Cốt Lõi

- ✗ **Dùng chung khóa**: 1 khóa cho Enc và MAC.
- ✗ **MAC MD5 yếu**: Dễ bị tấn công độ dài.
- ✗ **Bắt tay hở**: Bị MITM ép hạ cấp bộ mã.
- ✗ **Thiếu đóng phiên**: Bị cắt cụt bởi FIN giả.
- ✗ **Virtual Hosting**: Mặc định 1 IP/1 host.

**Bị cấm theo RFC 6176 (03/2011)**

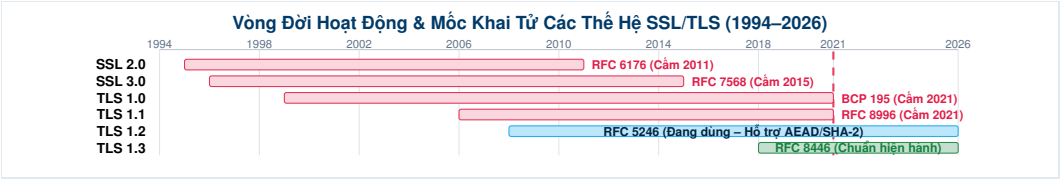
## SSL 3.0 (11/1996) – Định Hình & Khai Tử

- ✓ **Đóng góp kiến trúc**: Tách 2 tầng Record & Handshake, tách khóa mã hóa/MAC, thêm `Finished` và `close_notify`.
- ✗ **Lỗ hổng POODLE (2014)**: Lỗi đệm khối CBC, bị giải mã từng byte dữ liệu.
- ✗ **Suy yếu RC4 & Thiếu Extensions**: RC4 bị lệch thống kê; thiếu trường mở rộng nên không vá được CBC.

**Bị khai tử theo RFC 7568 (06/2015)**

# Chuẩn Hóa IETF (TLS 1.0 – 1.3) & Khai Tử Thế Hệ Cũ






## 4 Thế Hệ Chuẩn Hóa TLS tại IETF

- **TLS 1.0 (1999, RFC 2246)**: Chuẩn hóa HMAC, PRF; yếu do IV ngầm định CBC (lỗ hổng BEAST).
- **TLS 1.1 (2006, RFC 4346)**: IV tường minh cho từng bản ghi CBC; ẩn lỗi đệm chống tấn công định thời.
- **TLS 1.2 (2008, RFC 5246)**: PRF SHA-2, đàm phán chữ ký, bổ sung AEAD (`AES-GCM`); cấm MD5.
- **TLS 1.3 (2018, RFC 8446)**: Bắt buộc AEAD và PFS (`ECDHE`); loại bỏ CBC, SHA-1, RSA tĩnh.

## 3 Lý Do Cấm TLS 1.0 & 1.1 (BCP 195)

1. **Thiếu AEAD**: Buộc duy trì bộ mã khối CBC cũ `3DES-EDE-CBC-SHA`.
2. **Phụ thuộc SHA-1**: Chữ ký số bắt tay gắn SHA-1 yếu ($2^{77}$ phép tính).
3. **Phình đại mã nguồn**: Tăng bề mặt tấn công; PCI DSS cấm từ 2018.

# Bảng Tổng Hợp Đối Chiếu 7 Phiên Bản SSL/TLS

| Phiên bản | Năm | Mã Byte | Trạng thái | Cải tiến Kỹ thuật Chính | Nguyên nhân Đào thải / Quy định |
|---|---|---|---|---|---|
| **SSL 1.0** | 1994 | N/A | Chưa phát hành | Nguyên mẫu nội bộ Netscape | Lỗi bảo mật cấu trúc ngay từ thiết kế. |
| **SSL 2.0** | 1995 | {00,02} | ✗ Cấm (RFC 6176) | Mã hóa kênh truyền Web đầu tiên | Chung khóa Enc/MAC, MD5 yếu, thiếu bảo vệ bắt tay. |
| **SSL 3.0** | 1996 | {03,00} | ✗ Khai tử (RFC 7568) | 2 tầng Record/Handshake, tách khóa | Lỗ hổng POODLE trên CBC, lệch RC4, thiếu Extensions. |
| **TLS 1.0** | 1999 | {03,01} | ✗ Khai tử (RFC 8996) | Chuẩn hóa HMAC, PRF, Extensions | IV ngầm định trong CBC (BEAST), thiếu AEAD. |
| **TLS 1.1** | 2006 | {03,02} | ✗ Khai tử (RFC 8996) | Explicit IV từng bản ghi, ẩn lỗi đệm CBC | Bắt tay gắn cứng SHA-1 ($2^{77}$ phép tính), thiếu AEAD. |
| **TLS 1.2** | 2008 | {03,03} | ✓ Đang dùng | PRF họ SHA-2, bổ sung AEAD (GCM/CCM) | Đóng băng tính năng mới; cấm MD5/SHA-1 (RFC 9155). |
| **TLS 1.3** | 2018 | {03,03}+Ext | ✓ Hiện hành | Bắt buộc AEAD & PFS (ECDHE), HKDF | Loại bỏ hoàn toàn CBC, RC4, SHA-1 và RSA tĩnh. |

**Kết luận then chốt:** Bốn phiên bản SSL 2.0 đến TLS 1.1 đều đã bị IETF cấm đàm phán tuyệt đối (*MUST NOT*). Hiện chỉ cho phép vận hành an toàn trên TLS 1.2 (cấu hình AEAD/PFS) và TLS 1.3.

# Quản Lý Trạng Thái: Session vs. Connection State

## Trạng Thái Phiên (Session State)

- **Bản chất**: Liên kết logic lâu dài tạo qua Handshake, dùng chung cho nhiều kết nối.
- **Hiệu năng**: Nối lại phiên (Session Resumption) nhanh, giảm độ trễ bắt tay.
- **6 tham số trạng thái**:
  - Session Identifier & Peer Certificate (X.509).
  - Compression Method & Cipher Spec.
  - Master Secret (48 byte) & cờ Is Resumable.

## Trạng Thái Kết Nối (Connection State)

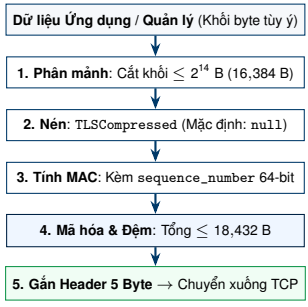
- **Bản chất**: Liên kết truyền tải tạm thời (*transient*), gắn với 1 phiên tại mỗi thời điểm.
- **6 tham số vận hành riêng 2 chiều**:
  - Server/Client Random: Chuỗi nonces độc lập.
  - Write MAC Secret & Write Key riêng 2 chiều.
  - Initialization Vectors (IV) & Sequence Number.

**Cơ chế chuyển trạng thái nguyên tử:** Thông số mới đàm phán được nạp vào Pending State. Khi nhận/gửi bản tin `ChangeCipherSpec`, hệ thống mới đồng bộ sao chép đè sang Current State.

# Giao Thức Record Protocol: 5 Bước Đóng Gói



## Luồng Đóng Gói Tại Tầng Bản Ghi




## Chi Tiết 5 Công Đoạn Xử Lý Tuần Tự

1. **Phân mảnh (Fragmentation)**: Cắt dữ liệu thành từng mảnh $\leq 2^{14}$ byte (16,384 B) dạng `TLSPlaintext`.
2. **Nén (Compression)**: Mặc định `null` (không nén) để loại trừ rò rỉ qua tấn công CRIME.
3. **Gắn MAC**: Dùng `write_mac_secret` tính HMAC kèm `sequence_number` 64-bit ngầm định chống chèn/xóa gói.
4. **Mã hóa & Đệm**: Mã hóa đối xứng dữ liệu và MAC; tổng độ dài khối $\leq$ 18,432 B.
5. **Gắn Record Header (5B)**: Gồm Content Type (1B: CCS, Alert, Handshake, App), Version (2B) và Length (2B).

# Giao Thức Quản Lý: Change Cipher Spec & Alert

## Change Cipher Spec Protocol (Type 20)

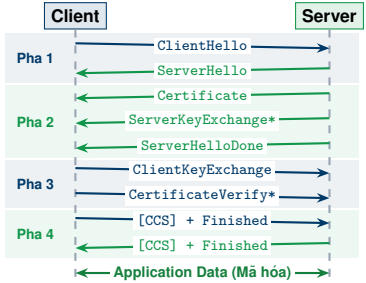
- **Cấu trúc tối giản**: Chỉ gồm đúng 1 byte mang giá trị 1.
- **Độc lập kiến trúc**: Giao thức riêng trên Record (Type 20), không phải bản tin con của Handshake.
- **Đồng bộ hóa mật mã**:
  - Báo hiệu đầu cuối sao chép Pending State sang Current State.
  - Kích hoạt bộ khóa phiên và thuật toán mới cho bản ghi kế tiếp.
  - Đặt lại bộ đếm `sequence_number` về 0.

## Alert Protocol (Type 21)

- **Cấu trúc 2 byte**: Severity (1=Warning, 2=Fatal) + Alert Code.
- **Mức Fatal (Level 2 – Hủy phiên)**:
  - `bad_record_mac` (lỗi MAC/CBC), `handshake_failure` (lệch mã).
  - `unexpected_message`, `decompression_failure`.
- **Mức Warning (Level 1 – Cảnh báo)**:
  - `close_notify`: Báo đóng phiên chuẩn, chống cắt cụt TCP.
  - Lỗi chứng thư: `bad_certificate`, `expired`, `revoked`.

# Giao Thức Bắt Tay (Handshake): 4 Pha Thiết Lập

## Luồng Bản Tin Bắt Tay (Full Handshake)




Khung bản tin: `Type (1B)` + `Length (3B)` + `Content`.

## Ý Chính Của 4 Pha Đàm Phán

1. **Pha 1 – Đàm phán năng lực**: Gửi `ClientHello` & `ServerHello` chốt phiên bản, trao đổi nonces ngẫu nhiên và chọn bộ mã.
2. **Pha 2 – Xác thực Server & Khóa tạm**: Server gửi chứng thư X.509, tham số khóa tạm (`ECDHE`) ký số và chốt bằng `ServerHelloDone`.
3. **Pha 3 – Trao đổi khóa & Client**: Client xác minh chứng thư, gửi khóa tạm (`pre_master_secret`) và chứng thư nếu dùng mTLS.
4. **Pha 4 – Kích hoạt & Hoàn tất**: Hai bên gửi `ChangeCipherSpec` bật mã hóa, rồi gửi `Finished` xác thực toàn bộ lịch sử bắt tay.

# Giải Phẫu Bộ Mã Hóa (Cipher Suite) & Chuẩn PFS






### 1. Trao Đổi Khóa & Chuẩn PFS (ECDHE)

- **RSA tĩnh (Đã bỏ)**: Khóa phiên mã hóa bằng chứng thư; lộ khóa riêng làm lộ toàn bộ dữ liệu cũ.
- **ECDHE / DHE (PFS)**: Sinh cặp khóa tạm mỗi phiên; bảo vệ dữ liệu quá khứ.

### 2. Xác Thực Định Danh (RSA / ECDSA)

- **Nguyên lý**: Xác minh chứng thư X.509 và chữ ký số trên khóa tạm.
- **Quy định**: Cấm chế độ ẩn danh (ADH) để triệt tiêu nguy cơ MITM.

### 3. Mã Hóa Dữ Liệu (AES-GCM / ChaCha20)

- **Đào thải**: Loại bỏ RC4, 3DES và chế độ khối CBC rò rỉ đệm.
- **Chuẩn AEAD**: Hợp nhất mã hóa và xác thực (AES-GCM, ChaCha20).

### 4. Hàm Băm PRF & Tinh Giản TLS 1.3

- **Hàm băm PRF**: Hậu tố SHA384/SHA256 phục vụ dẫn xuất khóa.
- **Cú pháp TLS 1.3**: Tinh giản chỉ còn cặp AEAD + HKDF.

# Mô Hình Mật Mã Lai & Cơ Chế Dẫn Xuất Khóa Phiên

**Mô hình Mật mã lai (Hybrid Cryptography):** Dùng mật mã bất đối xứng khi bắt tay để thỏa thuận bí mật ban đầu, sau đó dẫn xuất ra bộ khóa đối xứng để mã hóa dữ liệu tốc độ cao ở tầng Record.

## Giai Đoạn 1: Tạo `master_secret` (48 Byte)

- **1. Thiết lập** `pre_master_secret`:
  - *RSA*: Client sinh 48B, mã hóa bằng khóa Server.
  - *ECDHE / DHE*: Trao đổi khóa tạm, tự tính bí mật chung.
- **2. Dẫn xuất qua hàm PRF**:

$$\texttt{master_secret} = \text{PRF}(\texttt{pre_ms}, \text{"master secret"}, \texttt{ClientRand} + \texttt{ServerRand})$$

- **Chống phát lại**: Nhờ nonces mới mỗi phiên, `master_secret` luôn duy nhất.

## Giai Đoạn 2: Mở Rộng `key_block` Vận Hành

- Mở rộng `master_secret` thành `key_block`, chia 4 khóa và 2 IV:

| cl_MAC | srv_MAC | cl_key | srv_key | cl_IV | srv_IV |
|---|---|---|---|---|---|

- **Tách biệt khóa 2 chiều**: 3 cặp tham số độc lập gồm khóa MAC, khóa mã hóa và vector IV cho hai chiều Client/Server.
- **Chống phản xạ**: Khóa 2 chiều độc lập ngăn gói tin dội ngược bên gửi.

# Hạ Tầng PKI & Cấu Trúc Chứng Thư Số X.509 v3



## Vai Trò PKI & Chuỗi Tin Cậy

- **Mục tiêu cốt lõi**: Ngăn chặn MITM tráo khóa công khai khi bắt tay.
- **Chứng thư X.509 v3**: Căn cước điện tử gắn khóa công khai với danh tính chủ thể.
- **Nguyên tắc bảo mật**: Chứng thư công khai; khóa riêng lưu tuyệt mật tại máy chủ.
- **Xác minh chuỗi CA**: Trình duyệt dùng Root CA tin cậy để thẩm tra chữ ký CA cấp.
- **Định dạng lưu trữ**: Nhị phân `DER`, Base64 `PEM`, gói `PKCS#7`.

## Cấu Trúc Trường Cơ Bản & Mở Rộng X.509 v3

- **Version & Serial**: Chuẩn phiên bản v3; số serial duy nhất do CA ấn định.
- **Issuer & Subject**: Tên phân biệt (DN) của bên cấp chứng thực và chủ thể sở hữu.
- **Validity & Khóa**: Thời hạn hiệu lực và khóa công khai (`RSA`, `ECDSA`).
- **Chữ ký & Mở rộng SAN**: Chữ ký số CA; mở rộng SAN gắn nhiều tên miền trên 1 chứng thư.
- **Kiểm tra thu hồi**: Tra cứu trạng thái qua danh sách `CRL` hoặc trực tuyến `OCSP`.

# Tổng Kết: Kiến Trúc Bền Bỉ & 3 Bài Học Mật Mã

**Sự bền bỉ của kiến trúc nền tảng (> 30 năm):** Mô hình phân tách hai tầng giữa Record Protocol (xử lý dữ liệu đối xứng) và Handshake Protocol (đàm phán, xác thực PKI), cùng sự phân định Session State và Connection State, vẫn là xương sống cho mọi phiên bản TLS hiện đại.

## 1. Cấm Hạ Cấp (*MUST NOT*)

- **Nguy cơ**: Tự động lùi về giao thức cũ tương thích ngược là bề mặt tấn công nguy hiểm nhất.
- **Chính sách**: IETF cấm triệt để ở cấp mã nguồn (*MUST NOT*) với bản cũ.

## 2. Hợp Nhất Sang AEAD

- **Khiếm khuyết**: Cơ chế `MAC-Pad-Encrypt` rời rạc trong CBC gây rò rỉ đệm (POODLE).
- **Giải pháp**: Bắt buộc hợp nhất mã hóa và toàn vẹn vào một thao tác nguyên tử với AEAD.

## 3. Bắt Buộc Chuẩn PFS

- **Nguy cơ**: Lộ khóa riêng dài hạn của chứng thư không được làm lộ dữ liệu trong quá khứ.
- **Thực thi**: Khai tử RSA tĩnh, chuyển sang khóa phù du ECDHE / DHE.

# Danh Mục Tài Liệu Tham Khảo

## Tiêu Chuẩn Kỹ Thuật IETF RFC


1. **RFC 8446** / **9846**: *TLS Protocol Version 1.3* (2018 / 2024).
2. **RFC 8996 (BCP 195)**: *Deprecating TLS 1.0 and TLS 1.1* (2021).
3. **RFC 5246**: *The TLS Protocol Version 1.2* (2008).
4. **RFC 4346 & 2246**: *TLS 1.1 (2006) & TLS 1.0 (1999).*
5. **RFC 7568 & 6101**: *Deprecating SSL 3.0 & Historic Spec.*
6. **RFC 6176 & 7465**: *Prohibiting SSL 2.0 & RC4 Suites.*
7. **RFC 5280**: *Internet X.509 PKI Certificate Profile* (2008).


## Tiêu Chuẩn NIST & Tài Liệu Học Thuật


8. **NIST SP 800-52 Rev. 2**: *Guidelines for TLS Implementations* (2019).
9. **William Stallings**: *Network Security Essentials*, Pearson, Ch. 5.
10. **Carnegie Mellon Univ.**: *18-731 Readings in SSL/TLS* (Spring 2015).
11. **PCI SSC**: *Migrating from SSL and Early TLS* (2018).
12. **F5 DevCentral**: *TLS Cipher Suite Best Practices Guide* (2024).
13. **Microsoft Learn**: *X.509 Digital Certificates Architecture Guide* (2023).


Toàn bộ số liệu, mã phiên bản và cơ chế mật mã trong bài trình bày được đối chiếu trực tiếp từ đặc tả chuẩn IETF RFC và NIST SP 800-52.

# CẢM ƠN CÔ VÀ CÁC BẠN ĐÃ LẮNG NGHE!

## PHIÊN THẢO LUẬN & CÂU HỎI (Q&A)

**Nhóm Sinh viên Thực hiện**

Lê Minh Sơn – Mai Tiến Dũng – Nguyễn Nho Dương

Giảng viên hướng dẫn: **TS. Lê Thị Hợi**

Khoa Công nghệ Thông tin – Trường Đại học Công nghệ, ĐHQGHN